ANISAS — Session Handover (AGENTS.md)

> Give this file to any new AI chat session to instantly restore full context of the ANISAS Enterprise Platform work: environment, architecture, all fixes & optimizations completed so far, known gotchas, and next steps.

---

1. Environment & How to Run

Item	Value
App URL	`http://localhost:9000`
Working dir	`C:\Users\harshal Patel\OneDrive\Desktop\Cybersecurity\ANISAS_Enterprise_Platform\ai-service`
Python	`C:\Users\harshal Patel\AppData\Local\Programs\Python\Python314\python.exe` (3.14.5)
Server start	`python main.py` (FastAPI/uvicorn on `0.0.0.0:9000`)
Frontend	Single-file SPA `ai-service\static\index.html` — **edits need NO server restart**
API keys	`CENSYS_API_KEY=1b32ab30-4621-4a98-b571-b4b4ea1e0e8c`, `PORT=9000`
Browser	Chrome at `C:\Program Files\Google\Chrome\Application\chrome.exe`; headless via `--remote-debugging-port=9222`

Start the server (background, no terminal window):

```
Start-Process -FilePath "C:\Users\harshal Patel\AppData\Local\Programs\Python\Python314\python.exe" -ArgumentL
```

Verify with `Invoke-WebRequest -Uri "http://localhost:9000/" -UseBasicParsing -TimeoutSec 5`.

Compile check after any `.py` edit:

```
& "C:\Users\harshal Patel\AppData\Local\Programs\Python\Python314\python.exe" -c "import py_compile; py_compil
```

---

2. Tooling & Constraints

- **No node.js, no pytest.** Python libs available: `websockets 16.1.1`, `requests 2.31.0`, FastAPI/uvicorn.
- **CDP test pattern**: headless Chrome with `--remote-debugging-port=9222`; use a single `recv_loop` task dispatching to `pending` futures. CDP result nesting is `r['result']['result']['value']` (**double-wrapped**).
- **Server stability**: the server occasionally crashes during long scans (background thread issue). Restart it before/after long scan tests. `execute_iot_intelligence` blocks a FastAPI thread for

30–60s per public IP — this is a known architectural limitation.
- **Static frontend edits** (`static/index.html`) take effect on next page refresh — no server restart needed.

---

3. Ground Truth (verified scan baselines)

IP	Expected result
`.133` (LAN)	AS140061, 480 vulns, 30 ports
`193.32.162.75`	60 vulns
`185.220.101.5`	0 vulns (clean)
`8.8.8.8`	0 vulns (clean)
`1.1.1.1`	0 vulns (clean)
`188.130.44.39`	0 direct InternetDB vulns BUT NVD correlation yields 12 IIS CVEs (incl. CVE-2008-1446 CRITICAL 9.0)

---

4. Architecture / Data Flow (Module 4 IoT)

Single-target scan flow (`main.py`)

1. `POST /api/v1/iot/scan` (`api_create_iot_scan` , L5047) → `execute_iot_intelligence(scan_id, ip, force_refresh=True)` (L3103).
2. `scan_single_target(ip)` (in `iot_recon_engine.py` , L1128) — **parallelized**, see §5.
3. `fetch_shodan(ip)` (L323) → Shodan Host API (needs `SHODAN_API_KEY`) **else** InternetDB (`internetdb.shodan.io/{ip}` , free: ports/hostnames/cpes/vulns) **then** `fetch_censys(ip)` (L443, needs `CENSYS_API_KEY`). Returns `{ports, cpes, products, banners, vulns, source}` .
4. `get_cve_data(ip, vuln_ids=...)` (L2682) → if InternetDB vulns exist, fetch details from `cvedb.shodan.io/cve/{id}` with NVD fallback. If `vuln_ids` empty → returns "No CVEs found" early.
5. **Fallback**: if `service_cve_matches` is empty → `correlate_service_cves(shodan_products, shodan_banners, embedded_server, ip, port_ports=open_ports)` (L2621, called at L3262 single-target / L4170 subnet). Uses `PORT_SOFTWARE_MAP` (L2540) → `_SERVER_SOFTWARE_ALLOWLIST` (L2606) → `_query_service_cves` (L2563) NVD keyword search.

Subnet scan flow

- `POST /api/v1/iot/scan` with `mode:"subnet"` /cidr → `_run_subnet_scan_background` (L5039) → `execute_subnet_iot_intelligence` (L4256) → `_subnet_scan_one_host` (L4139) → `_subnet_light_recon` (L4056).
- Progress polled via `GET /api/v1/iot/subnet/progress?scanId=...` .
- WS-Discovery only runs for **LAN/private IPs** (public IPs skip it to avoid router false positives).

Frontend flow (`static/index.html`)

- `executeSingleScan()` (L2535) → `maybeAutoRunModule4()` (L2323) → `triggerAutoSubnetScan()` (L2414)
- `checkSubnetOnce(scanId)` (L2254).
- `renderModule4(iotData, target)` (L1834) renders the Module 4 dashboard, incl. ONVIF/RTSP column.

---

5. Optimizations Applied (scan speed)

Change	Where	Result
Parallel probes (RTSP/HTTP/ONVIF/NVD/VT/AbuseIPDB/network-owner)	`iot_recon_engine.py` `scan_single_target` L1128 (ThreadPoolExecutor `max_workers=8`, per-future timeout 12s)	~60s → ~4s per IP
Shodan rate gate 1.0s → 0.15s	`main.py` L283 `_INTERNETDB_MIN_INTERVAL`	~14s saved / 20 hosts
Censys rate gate 0.35s → 0.15s	`main.py` L284 `_CENSYS_MIN_INTERVAL`	~4s saved / 20 hosts
NVD candidates 4 → 2	`correlate_service_cves` `max_candidates=2` (L2621)	~16s worst case
NVD per-query timeout 8→5s, per-CVE detail 10→5s	`_query_service_cves` L2569, `_get_cve_data_uncached`	~10–20s worst case
Shodan CVEDB timeout 8→4s	`_get_cve_data_uncached` L2727	~4s per CVE
Recon-engine API timeouts 3–4s → 2–3s	`iot_recon_engine.py` throughout	~10–20s worst case
Nmap subprocess timeout 30→10s	`iot_extended_intel.py` L496	~20s worst case
Subnet per-host budget 120→30s; scan deadline max 2400→600s	`execute_subnet_iot_intelligence` L4293-4294	~90s per hung host

Expected: single IP scan ~30–60s (was 5+ min), subnet /24 ~30–90s (was 3–5 min).

---

6. CVE Discovery Fix (188.130.44.39 showed 0 CVEs)

Root cause: InternetDB returned `vulns: []` for this IIS host, and no `SHODAN_API_KEY` / `CENSYS_API_KEY` were set in the running environment → no products/banners → `correlate_service_cves` had nothing to correlate (port 21/80 weren't in `PORT_SOFTWARE_MAP`).

Fix (all in `main.py`):
1. `PORT_SOFTWARE_MAP` (L2540) — added `21/80/443 → "Microsoft Internet Information Services"`, `22 → "OpenSSH"`, `25 → "Postfix"`.
2. `_SERVER_SOFTWARE_ALLOWLIST` (L2606) — added `"microsoft internet information services"`.
3. `_query_service_cves` (L2563) — `resultsPerPage=20`, iterate all 20, then `sort by cvssScore desc` and keep top 12 (previously took first 4 in ID order, missing newer CVEs).

Verified: `188.130.44.39` now returns **12 CVEs** including CVE-2008-1446 (CRITICAL 9.0, IPP integer overflow — matches Shodan). CVE-2009-2521 (IIS FTP DoS) exists on NVD but is beyond the first 20 keyword results; a port-21-specific search would need `keywordSearch=Microsoft+Internet+Information+Services+FTP`.

Note: `get_cve_data` still short-circuits to 0 CVEs when `vuln_ids` is empty — that's expected; the correlation fallback (step 5 in §4) is what now catches these hosts.

---

7. ONVIF / RTSP Endpoint Features

- **Backend**: `POST /api/v1/iot/probe-endpoints` (L5124, `api_probe_endpoints`) — sends ONVIF SOAP `GetDeviceInformation` to 80/8080/443, RTSP OPTIONS+DESCRIBE on 7 brand-specific paths, WS-Discovery (LAN only). Returns per-protocol `{status, accessible, needsAuth, primaryUrl, manufacturer}`.
- **Frontend**: `copyRtsp(url)` (L1608, global) and `probeAssetEndpoints(ip, btn)` (L1614, global) **must stay in global scope** (called via `onclick` attributes). `_guessRtspPath` (L1846), `_guessRtspUrl` (L1858), `_hasPort` (L1842), `_renderEndpoints` (L1862) are local to `renderModule4`.
- **Brand RTSP paths**: Hikvision `/Streaming/Channels/101`, Dahua `/cam/realmonitor?channel=1&subtype=0`, Axis `/axis-media/media.amp`, Reolink `/h264Preview_01_main`, Foscam `/videoMain`, Vivotek `/live.sdp`, Uniview `/media/video1`, Hanwha `/profile1/media.smp`, Unknown `/live`.
- **VERIFY button** next to ONVIF/RTSP buttons opens a modal with green/red per-protocol status.
- `copyRtsp` toast includes VLC/ffplay/OBS usage instructions.
- Module 4 table has a 7th column "ONVIF/RTSP ENDPOINTS"; all `colspan="6"` were updated to `colspan="7"`.

---

8. Subnet Auto-Start Fixes (scan didn't auto-run)

1. `triggerAutoSubnetScan` (L2414) — retries POST 3× with 2s delay; only sets `_lastSubnetScanId` after server confirms.
2. `executeSingleScan` (L2535) — no longer `await subnetPromise` in `finally` (fire-and-forget, notification on completion).
3. `maybeAutoRunModule4` (L2323) — always starts subnet scan if none running; polls existing scan in background without early return on stale scan IDs.

---

9. Terminal Window Fix (console popping up during scans)

3 `arp -a` subprocess calls opened visible console windows. Fixed by adding `CREATE_NO_WINDOW`:
- `main.py` L1782 (was `shell=True` — worst offender, spawned cmd.exe) → now `subprocess.check_output(["arp", "-a", clean_ip], creationflags=_nw)`.
- `iot_recon_engine.py` L369 → `creationflags=_nw` added.
- `iot_batch_discovery_engine.py` L165 → `creationflags=_nw` added.

Pattern used: `_nw = getattr(subprocess, "CREATE_NO_WINDOW", 0) if os.name == "nt" else 0`.

---

10. Other Completed Work

- M1 (ASN) fix: corrected ASN attribution + CVE count cap; verified against ground truth.
- Motion-layer reveal: `ani-reveal` + IntersectionObserver fix so CVE tables render (were invisible).

- M4 "DISCOVERED IOT ASSETS" card reflects subnet scan results; added 5th metric card "SUBNET CVE EXPOSURES" (`m4SubnetCveCount` , `m4SubnetCveCountDetail`).
- Toast/bell notification system.
- CVE separation model: `hardware_cve_matches` (vendor-gated, CRITICAL count) vs `service_cve_matches` (live service-level, always labeled with disclaimer).
- `IoTRequest` model (L2464) requires `scanId` field for all POSTs to `/api/v1/iot/scan` and `/api/v1/iot/probe-endpoints` .

---

11. Key Files & Line Reference (current)

File	Items
`ai-service/main.py`	FastAPI backend. `IoTRequest` L2464, `PORT_SOFTWARE_MAP` L2540, `_query_service_cves` L2563, `_SERVER_SOFTWARE_ALLOWLIST` L2606, `correlate_service_cves` L2621, `get_cve_data` L2682, `_get_cve_data_uncached` L2699, `execute_iot_intelligence` L3103, `_subnet_scan_one_host` L4139, `execute_subnet_iot_intelligence` L4256, `POST /api/v1/iot/scan` L5047, `GET /api/v1/iot/subnet/progress` L5070, `GET /api/v1/iot/{scan_id}` L5077, `POST /api/v1/iot/probe-endpoints` L5124
`ai-service/iot_recon_engine.py`	`scan_single_target` L1128 (parallelized), `classify_ip_address` L233, `resolve_network_owner_structured` L270, `fingerprint_hardware_vendor_and_device` L924
`ai-service/iot_extended_intel.py`	Extended OSINT fetchers (FOFA/ZoomEye/BinaryEdge/GreyNoise/OTX/CVE.org/EPSS); Nmap L496
`ai-service/iot_batch_discovery_engine.py`	Batch discovery; ARP at L165
`ai-service/module4_orchestrator.py`	RTSP/ONVIF/HTTP/TLS probe orchestration
`ai-service/probes/rtsp_probe.py`	RTSP OPTIONS probe
`ai-service/probes/onvif_probe.py`	ONVIF SOAP probe
`ai-service/static/index.html`	Frontend. `copyRtsp` L1608, `probeAssetEndpoints` L1614, `renderModule4` L1834 (`_hasPort` L1842, `_guessRtspPath` L1846, `_guessRtspUrl` L1858, `_renderEndpoints` L1862), `checkSubnetOnce` L2254, `maybeAutoRunModule4` L2323, `triggerAutoSubnetScan` L2414, `executeSingleScan` L2535
`%TEMP%\opencode\m4test\`	CDP test scripts (`check_shodan.py` , `check_censys.py`)

---

12. Known Issues / Next Steps

1. **Server instability**: long scans can crash the background thread — needs restart. Consider moving `execute_iot_intelligence` off the FastAPI thread pool (background worker) to prevent blocking/crash.
2. **No `SHODAN_API_KEY`** in the environment → Shodan Host API never used; only free InternetDB. Setting `SHODAN_API_KEY` would surface per-port products/banners and exact CVE matches (like the Shodan website shows). Same for Censys PAT (currently only `CENSYS_API_KEY` is known).

3. **CVE-2009-2521** not surfaced (beyond first 20 NVD keyword results). Optional: add a port-21 second keyword query `"Microsoft Internet Information Services FTP"` to `_query_service_cves`.
4. **Full end-to-end timed scan** not yet re-verified after the latest CVE/NVD changes — run a real IP scan and confirm: scan completes in reasonable time, subnet auto-starts, M04 populates with assets, VERIFY button works against a live camera/NVR.
5. `index.html` **`copyRtsp` / `probeAssetEndpoints`** must remain global scope — don't move inside `renderModule4`.

---

13. Verification Checklist (use before declaring a task done)

1. `py_compile` every touched `.py` file.
2. Server responds `200` on `http://localhost:9000/`.
3. Ground-truth IPs produce expected vuln counts (§3).
4. For "0 CVE" complaints: confirm `PORT_SOFTWARE_MAP` covers the open ports and the product names survive `_SERVER_SOFTWARE_ALLOWLIST` and `_clean_product_name`.
5. No visible terminal windows during scans (all subprocess calls use `CREATE_NO_WINDOW`).